

NCR MANAGER · QUALITY MANAGEMENT SYSTEM

Roles, Authorization & Security

The Kinetic Security Language (KSL) design — least-privilege teams, attributes and submission-scope policies.

DOCUMENT	VERSION	ISSUED	PLATFORM
ROLES AND SECURITY	1.0	June 27, 2026	Kinetic

CONFIDENTIAL · CONTROLLED DOCUMENT

Security is enforced with **Kinetic Security Language (KSL)** at space, kapp, form and submission scope, backed by **Teams** and **attributes** for organizational structure. The principle is **least privilege** with **site / business-unit boundaries**, **confidential-investigation isolation**, **supplier isolation** and **separation of duties**.

Personas → Teams

PERSONA	TEAM(S)	PRIMARY SCOPE
Quality Executive	Quality::Executive	Read-all, dashboards, management review approval
Quality Manager	Quality::Managers::{Site}	Approve/close CAPAs, MRB, escalations for their site
CAPA Owner	Quality::CAPA	Own & drive CAPAs; cannot self-approve effectiveness
Investigator	Quality::Investigators	Investigation, root cause, action execution
Manufacturing Operator	Operations::{Site}	Raise events; complete assigned training/actions
Process Owner	Operations::ProcessOwners	Process records, risks, change impact
Regulatory Affairs	Regulatory	Complaint reportability, MDR/MIR decisions, deadlines
Auditor	Quality::Audit	Audits & findings; auditor independence enforced
Supplier Quality Engineer	Supplier::SQE	Suppliers, SCARs, supplier audits
Document Control	Quality::DocControl	Documents, revisions, effective dates, distribution
Training Administrator	Quality::Training	Curricula, assignments, matrices
Supplier Contact	Supplier::External::{SupplierId}	Only their own SCARs (response portal)
System Administrator	Space Admin	Configuration; no record-approval authority

Authorization matrix (representative)

C =create R =read U =update A =approve/sign X =none. Read is always scoped to the persona's site/business unit unless noted "all".

RECORD	OPERATOR	INVESTIGATOR	CAPA OWNER	QUAL MGR	REG AFFAIRS	AUDITOR	SQE	DOC CTRL	SUPPLIER CONTACT	EXEC
Quality Event	C R	R U	R	R U A	R	R	R	R	X	R(all)
Nonconformance	R	C R U	R	R U A(MRB)	R	R	R	R	X	R(all)
CAPA	R	R U	C R U	R U A(close)	R	R	R	R	X	R(all)
CAPA effectiveness	X	X	R	A (independent)	X	X	X	X	X	R
Complaint	C R	R U	R	R U	R U A(reportability)	R	R	X	X	R(all)
Audit / Finding	X	R	R	R	R	C R U A	R(supplier)	X	X	R
Document / Change	R	R	R	R A	R	R	R	C R U A	X	R
Training record	R(self)	R	R	R	X	R	R	R	X	R
Supplier / SCAR	X	X	X	R	X	R	C R U A	X	R U(own)	R
Risk	R	R U	R	R A	R	R	R	R	X	R
Management Review	X	X	X	R	R	R	R	R	X	C R U A
Audit Trail / E-Sig	X	R	R	R	R	R	R	R	X	R

Key KSL policies (intent)

- **Site boundary** — `Record-scope` policy: `identity('teams').includes('Operations::' + values['Site'])` (or `Quality::Managers::` `{Site}`) for write; executives/quality get cross-site read.
- **Confidential investigations** — quality events with `Confidential = Yes` are readable only by the owner, assigned investigator and `Quality::Executive`; anonymous reporters are never disclosed.
- **Supplier isolation** — `Supplier::External::{SupplierId}` may read/update **only** SCARs whose `Supplier` business ID matches their team suffix; they can never see other suppliers or internal records.
- **Separation of duties** — effectiveness reviewer $\neq$ CAPA owner; change approver $\neq$ change author; signer identity is re-authenticated at signing time. Enforced by policy + workflow guard.
- **Auditor independence** — an auditor cannot be `Lead Auditor` on an audit of a site/team they own.
- **Field-level restriction** — regulatory fields (reportability, MDR type, benefit-risk) are writable only by `Regulatory` / `Quality::Managers`; everyone else sees them read-only.
- **Controlled override** — any policy override requires a reason and a second approval, captured in `audit-trail` with the overriding actor.

Electronic records & signatures (21 CFR Part 11)

- Signatures require **identity re-authentication** (the UI re-validates credentials before writing the signature; production should bind to the platform's authenticator/SSO step-up).
- Each signature records **printed name, timestamp, meaning, reason, record version, auth method** and a **tamper-evident hash**, associated with the signed record in the append-only `esignatures` manifest.
- An ordinary approval checkbox is **never** represented as automatically Part 11-compliant; signing is an explicit, reason-bearing, re-authenticated act with a configurable *meaning*.